S&P Capital IQ PRO

Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

BMV:BIMBO A (MI KEY: 4276592; SPCIQ KEY: 877906; TCUID: 53231)

Public

Year: Methodology Year: 2025
Question: Information Security Management Programs
Include Modeled Scores : Yes

Information Security Management Programs

Question

Does the company have programs on information security management?

Rationale

The information security threat landscape continues to grow and evolve, leveraging new and existing technologies to exploit vulnerabilities.

Given the importance of technical and procedural capabilities in safeguarding systems and critical information, as well as responding to information security threats, companies across all sectors are encouraged to establish robust management programs to test and protect their information systems.

These should include business continuity plans, vulnerability testing, internal and external audits and correct employees' behaviors, which are critical to ensuring companies' long-term sustainability.

This question examines whether companies are prepared to prevent and respond to significant information security incidents from a programmatic standpoint, as well as the public availability of information regarding these practices. It also assesses whether companies have experienced any material information security incidents in the most recent financial year.

Performance Summary

Question Level Company Performance	0
Question Weight	30
Year-on-Year Change	(35)
Industry Average Score	33
Industry Highest Score	100

The question layout and the company's verified information is provided below. No information is shown if the company did not provide any information or if it opted out of sharing non-public information.

Additional Question Guidance & Information Display

Key Definitions

Information security: Refers to the comprehensive measures taken to protect an information technology system from threats including malicious attacks, data loss, service disruptions, and any damage to its hardware, software, and stored data. The primary objective of information security is to mitigate information risk by ensuring the confidentiality, integrity, and availability of information.

Information security management systems: Governance and control mechanisms in place to safeguard information security.

Information Technology Infrastructure: Refers to the operational aspects of technology, covering both physical and software components.

Business continuity plans (BCP): A set of procedures to prevent potential threats, limit damages (contingency) and recover systems when they occur.

Vulnerability analysis: The analysis that a company conducts for defining, identifying, classifying, and prioritizing vulnerabilities in computer systems, applications, and network infrastructures. This provides the organization doing the assessment with the necessary knowledge, awareness and risk background to understand the threats to its environment and react appropriately. It is commonly included in internal and external audit processes, together with other procedures such as penetration testing, simulated hacker attacks and similar.

Data breach: Occurs when unauthorized parties access confidential and/or sensitive information of company's stakeholders and the overall organization.

Important note: *For the purpose of this question, references containing "information security", "cybersecurity" and "IT security" and similar terms are all equally accepted.*

Data Requirements

- If a company selects that yes, it has an information security management program in place but does not select any of the subsequent options, then the answer will not be accepted.
- Independent external audits/certifications which are expired at the time of the assessment are not considered valid to accept the related option.
- The escalation process for employees to report incidents, vulnerabilities or suspicious activities should direct them to the legal and compliance department, IT department or other similar internal stakeholders.
- Please note that the option "Information security awareness training" refers to training activities delivered to employees.

Disclosure Requirements

The information provided must be available in public reporting (e.g., strategy or risk section of an annual report, sustainability report, integrated report, or other company publications), or in a dedicated section (e.g., information security documents) of the corporate website.

Standards & Frameworks

CSRD - GOV-1 Governance Bodies Role, Key Actions, Metrics, SBM-3 Material Impacts Risks & Opportunities

Data View

QUESTION LEVEL INPUT	COMPANY ANSWER

Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

QUESTION LEVEL INPUT	COMPANY ANSWER
Company has a public information security management program which covers the listed elements	Not measured
Company has information security-related business continuity plans in place.	Not measured
Company has programs which include analysing vulnerabilities of its systems.	Not measured
Company conducts internal audits on its IT infrastructure and/or information security management systems.	Not measured
Company had its IT infrastructure and/or information security management systems audited by external auditors.	Not measured
Company has a clear information security escalation process which employees can follow.	Not measured
Company has information security awareness training in place for its employees.	Not measured
Company discloses the total number of information security breaches occurred in the last FY	Not measured
Company reports the total number of information security breaches occurred in the last FY	Not measured

Questionnaire

Does the company have an information security management program in place?

1. ○

   Yes, the company has an information security management program that covers the following elements. Please indicate where this information is available in **public reporting or corporate website.**

   1. ☐ Information security-related business continuity plans
   2. ☐ Information security vulnerability analysis
   3. ☐ Internal audits of the IT infrastructure and/or information security management systems
   4. ☐ Independent external audit of the IT infrastructure and/or information security management systems: please provide the names and standards used (such as ISO 27001):
   5. ☐ Escalation process for employees to report incidents, vulnerabilities or suspicious activities
   6. ☐ Information security awareness training
   7. ☐ Disclosure of total number of breaches occurred in last FY:

      Not measured

2. ◉

   No, the company does not publicly report on an information security management program which covers the listed elements.

3. ○

   Not applicable. Please provide explanations in the comment box below.

Confidential additional comments

Use the text field below only in the following cases: (i) to describe significant changes in data or calculation methodology compared to last year's submission, (ii) to explain why a question is not applicable to your company's business model, (iii) to explain if your data deviates from the unit or format requested, or (iv) to provide supporting notes on translations of non-English references.